COMPTE RENDU : ANALYSE ET CORRECTION DES VULNÉRABILITÉS

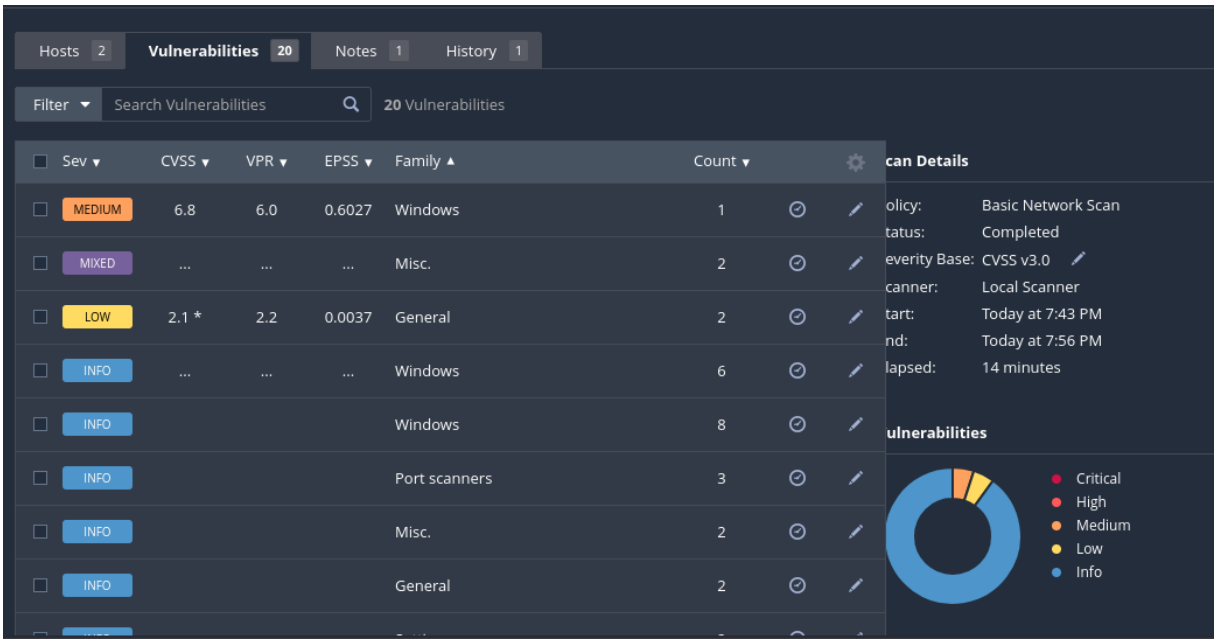
Cibles : Linux Ubuntu (192.168.56.10) et Windows 10 (192.168.56.20)

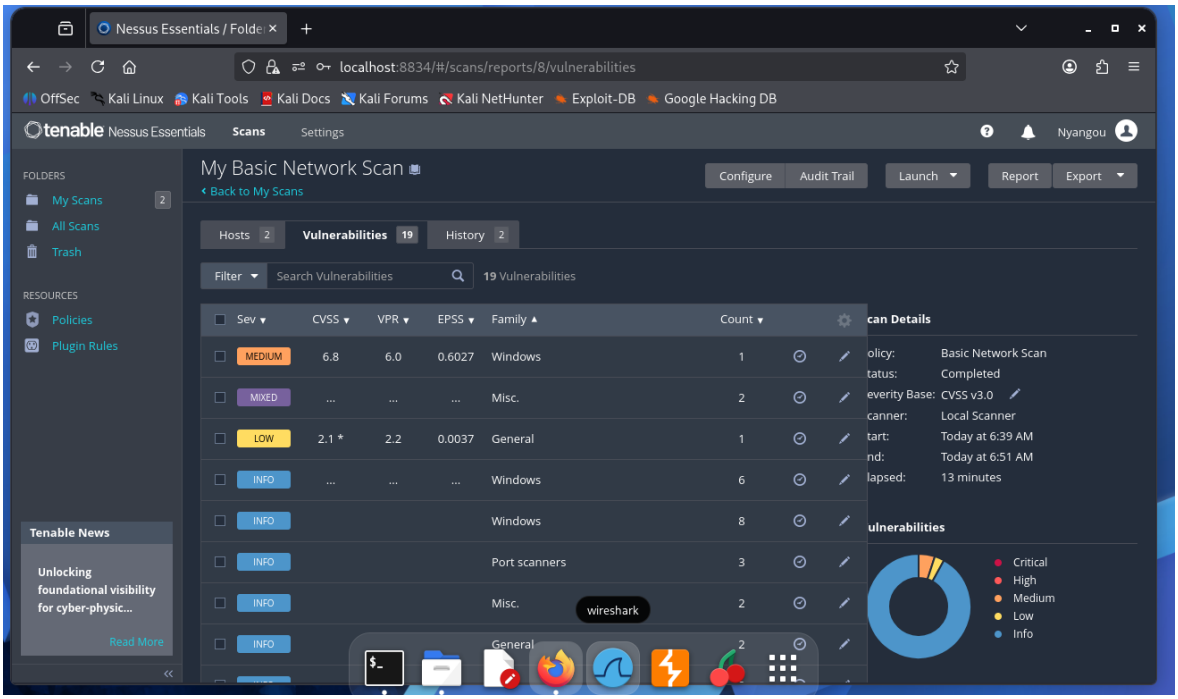
I. Objectif du TP

L'objectif est de passer de la phase de détection à la phase de remédiation. Après avoir identifié les failles de sécurité sur nos machines cibles, nous devons appliquer les correctifs nécessaires (mises à jour, configuration de pare-feu, désactivation de services) et vérifier l'efficacité de ces mesures par un nouveau scan.

II. Partie 1 : Analyse des vulnérabilités critiques

Toutes les vulnérabilités

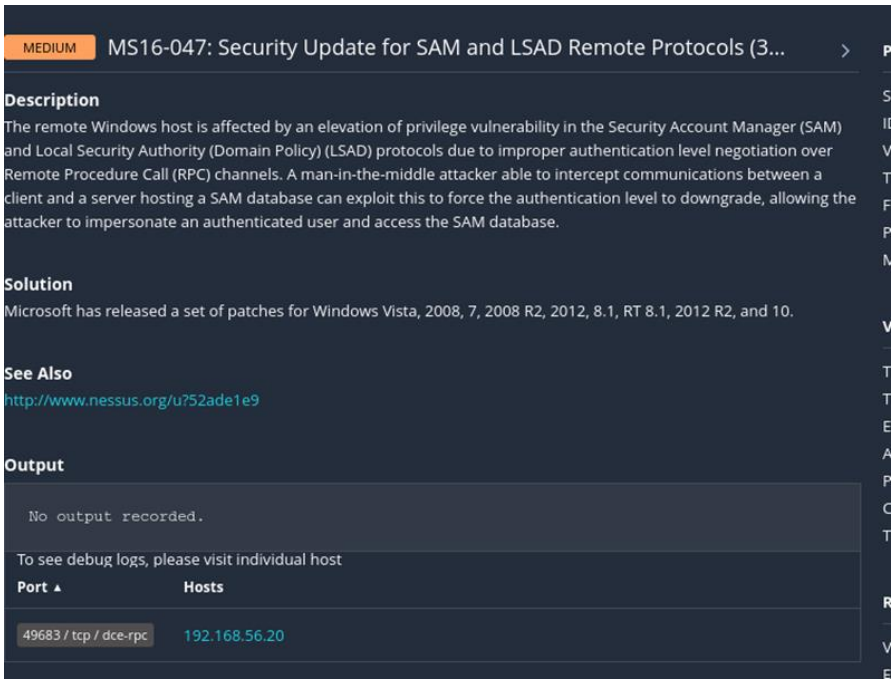




1. Analyse des vulnérabilités Windows (192.168.56.20)

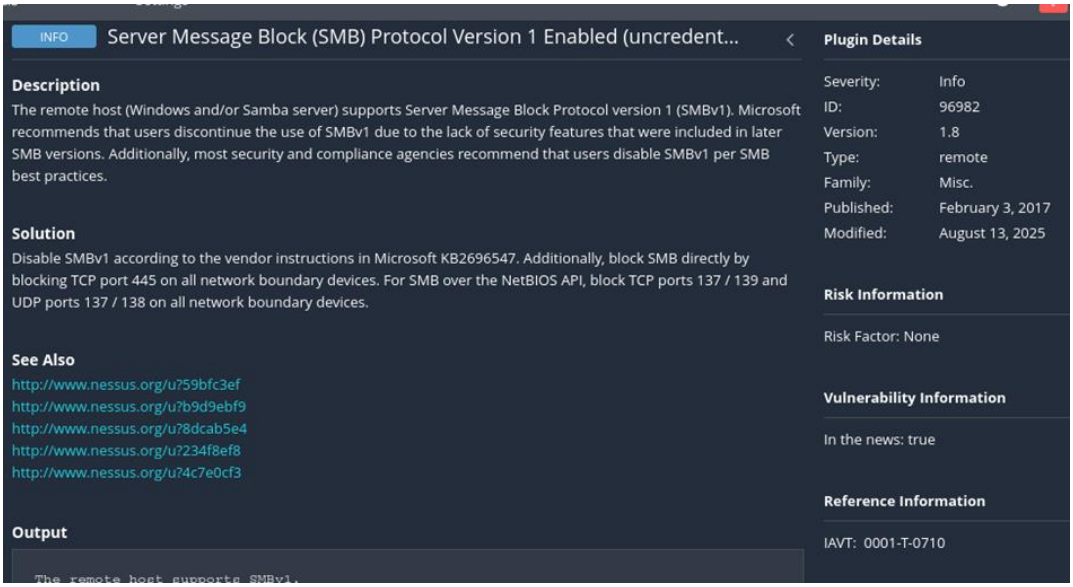
D'après le scan initial, deux vulnérabilités majeures ont été retenues :

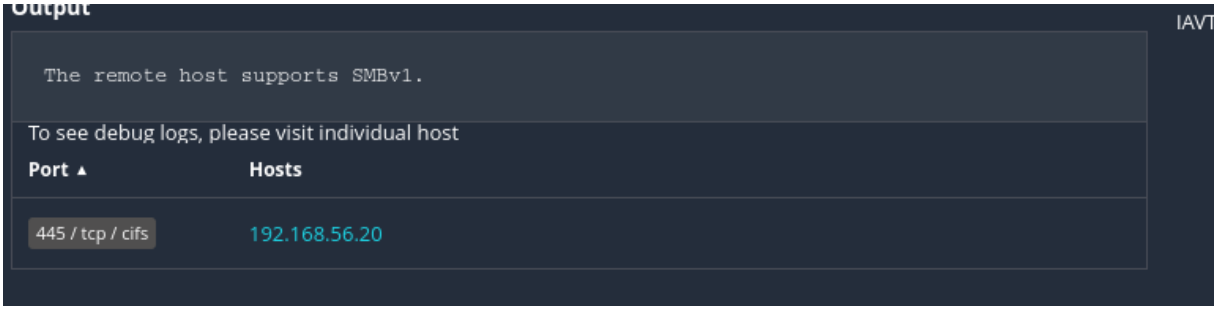
- Vulnerability A : MS16-047 (SAM and LSAD Remote Protocols)



- ✓ Problème : Une mauvaise négociation du niveau d'authentification dans les protocoles SAM/LSAD.
- ✓ Risque : Élévation de privilèges.
- ✓ Exploitation : Une attaque de type « Man-in-the-Middle » permet d'usurper l'identité d'un utilisateur authentifié.

- Vulnerability B: SMB Protocol Version 1 Enabled





- ✓ Problème : Le système accepte encore les connexions via le protocole obsolète SMBv1.
- ✓ Risque : Exposition à des ransomwares (ex : WannaCry) et interception de données.
- ✓ Exploitation : Un attaquant peut injecter du code arbitraire ou lire les fichiers partagés sans chiffrement moderne.

2. Analyse des vulnérabilités Linux (192.168.56.10)

   Sur la cible Ubuntu, les résultats montrent un niveau de risque plus faible (Low/Info) :

- Vulnerability C: ICMP Timestamp Request (General)
  - ✓ Problème : Le système répond aux requêtes de timestamp ICMP.
  - ✓ Risque : Divulgation d'informations (heure système précise).
  - ✓ Exploitation : Aide à la synchronisation d'attaques temporelles ou à la reconnaissance du réseau.

INFO Ethernet Card Manufacturer Detection

Description

Each ethernet MAC address starts with a 24-bit Organizationally Unique Identifier (OUI). These OUIs are registered by IEEE.

See Also

https://standards.ieee.org/faqs/regauth.html
http://www.nessus.org/u?794673b4

Output

```
The following card manufacturers were identified :

00:0C:29:A3:4D:ED : VMware, Inc.
```

To see debug logs, please visit individual host

Port ▲	Hosts
N/A	192.168.56.20

```
The following card manufacturers were identified :
```

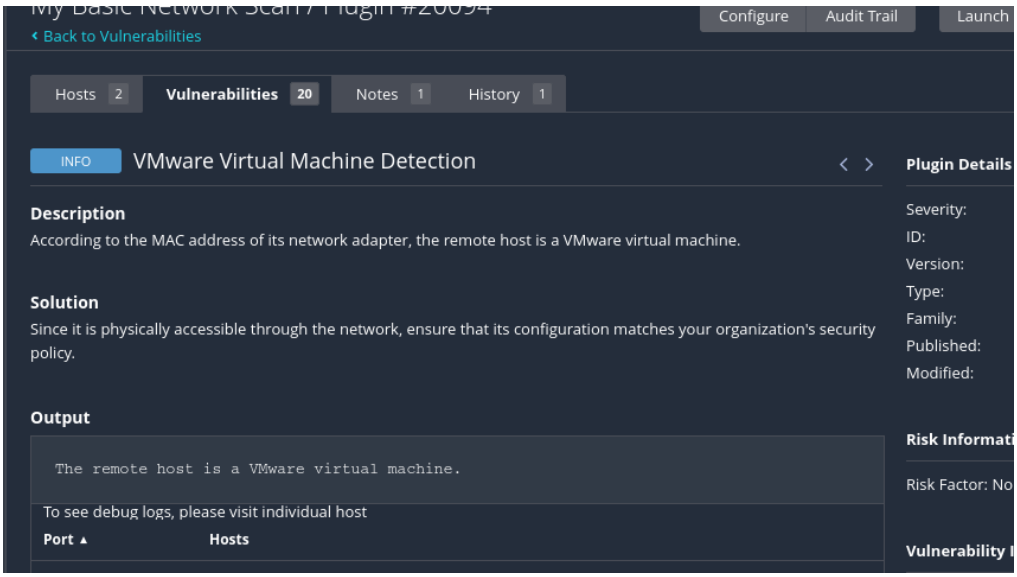
Plugin Details

Severity:	Info
ID:	35716
Version:	1.15
Type:	combined
Family:	Misc.
Published:	February 19, 200
Modified:	May 13, 2020

Risk Information

Risk Factor: None

- Vulnérabilité D : Service Detection
  - ✓ Problème : Plusieurs services exposent leur bannière d'identification.
  - ✓ Risque : Facilite la recherche d'exploits spécifiques à une version logicielle.

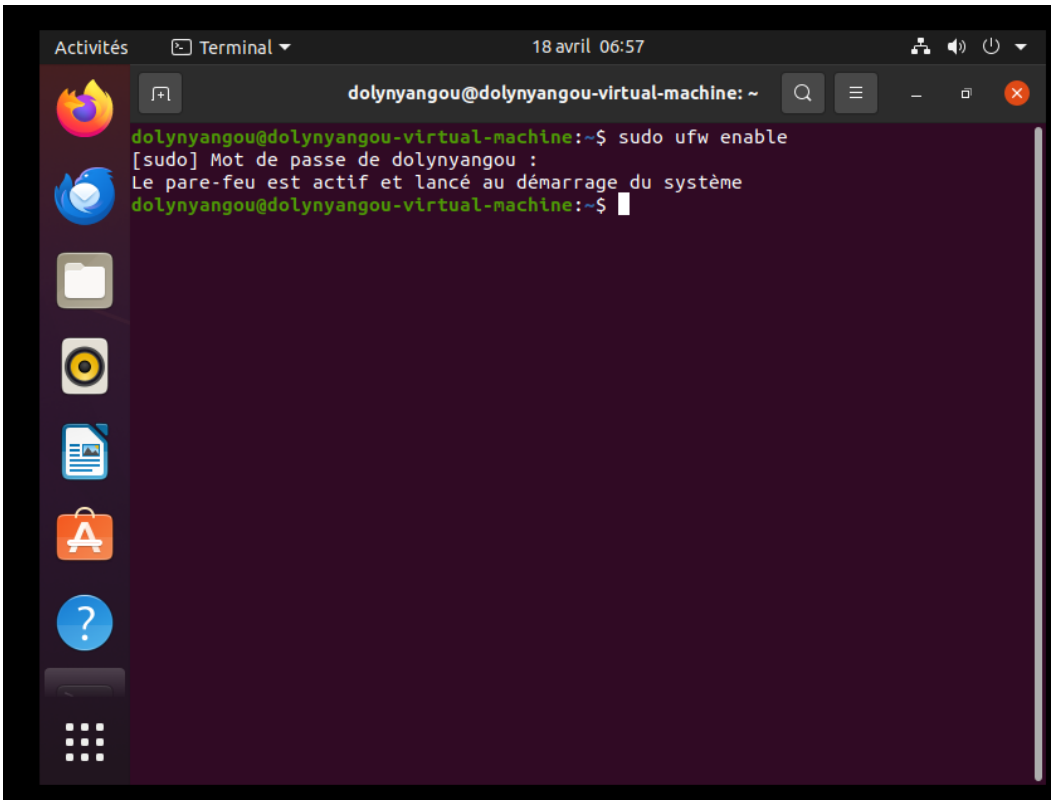


Partie 2 et 3 : Correction des vulnérabilités

Pour corriger ces failles, les manipulations suivantes ont été effectuées en mode administrateur.

1. Corrections sur Linux (Ubuntu)

Nous avons renforcé la sécurité via le terminal :



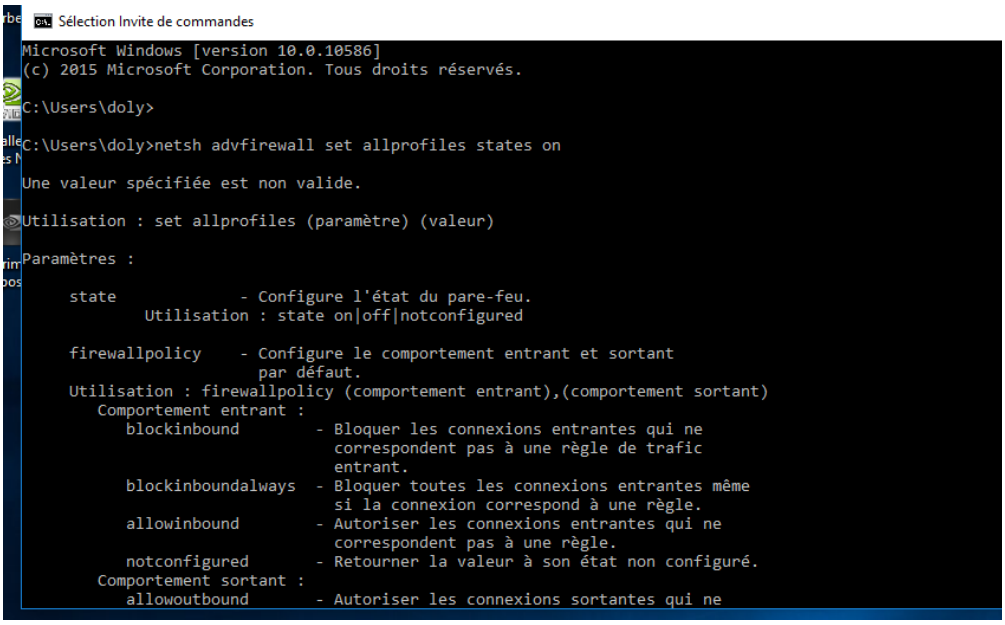
Puisque j'avais déjà fait les mises à jour des paquets au début des TP

- ✓ Pare-feu : Activation du pare-feu pour bloquer les requêtes non sollicitées : sudo ufw enable.

2. Corrections sur Windows 10

Nous avons utilisé l'invite de commande (Admin) et les paramètres système :

Pare-feu : Activation via la commande netsh advfirewall set allprofiles state on.



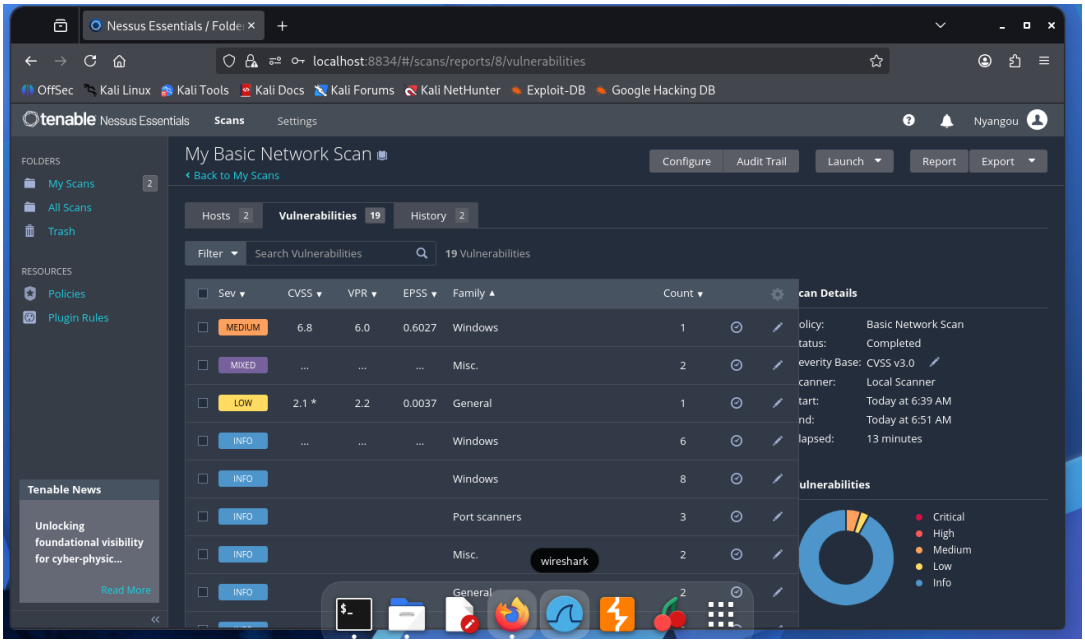
Partie 4 : Re-scan Nessus et Comparaison

Après avoir appliqué les corrections, un nouveau scan a été lancé.

- Résultats après correction :

✓ Avant : 20 vulnérabilités détectées (dont des niveaux Medium).
✓ Après : Réduction significative du nombre de vulnérabilités. Les failles critiques et medium liées à SMB et aux protocoles distants ont disparu.

Score CVSS : Amélioration globale de la note de sécurité du parc.



conclusion

Ce tp démontre l'importance de la phase de remédiation. La détection par Nessus n'est qu'une étape ; la sécurité réelle est obtenue en appliquant rigoureusement les correctifs et en configurant correctement le pare-feu. Le passage du mode « Détection » au mode « Correction » a permis de réduire drastiquement la surface d'attaque de nos machines.